CyberDefenders

RESOLUCIÓN DE LABORATORIO

Caso: 3CX Supply Chain (CyberDefenders)

Investigación basada en Threat Intelligence de un ataque de cadena de suministro. Análisis de instaladores MSI maliciosos y bibliotecas DLL para identificar las TTPs del atacante y atribuir la campaña al grupo Lazarus.

Sebastian David
Torres Reyes

Escenario:

Una gran corporación multinacional depende en gran medida del software 3CX para la comunicación telefónica, lo que lo convierte en un componente esencial de sus operaciones comerciales. Tras una reciente actualización de la app de escritorio 3CX, las alertas del antivirus detectan casos esporádicos de eliminación del software de algunas estaciones de trabajo, mientras que otras permanecen intactas. El equipo de TI, al descartarlo como un falso positivo, ignora las alertas y observa un rendimiento reducido y tráfico de red inusual hacia servidores desconocidos. Los empleados reportan problemas con la app 3CX, y el equipo de seguridad informática identifica patrones de comunicación inusuales relacionados con actualizaciones recientes del software.

Como analista de inteligencia de amenazas, es su responsabilidad examinar este posible ataque a la cadena de suministro. Sus objetivos son descubrir cómo los atacantes comprometieron la app 3CX, identificar al posible actor de la amenaza y evaluar el alcance general del incidente.

Herramientas utilizadas:

- VirusTotal

P1: Comprender el alcance del ataque e identificar qué versiones presentan un comportamiento malicioso es crucial para tomar decisiones informadas si estas versiones comprometidas están presentes en la organización. ¿Cuántas versiones de 3CX en Windows se han identificado como malware?

R: 2

La página web oficial de 3CX informó sobre una alerta de seguridad en Desktop App 3CX. Menciona que los números de versión 18.12.407 y 18.12.416 incluyen un problema de seguridad y que, además, algunos proveedores de antivirus han marcado y desinstalado el ejecutable 3CXDesktopApp.exe.

3cx.es/blog/alerta-seguridad-desktop-app/

3CX ¿CUÁL 3CX? ¿POR QUÉ 3CX? PRECIOS PRUEBA BLOG FORO

Alerta de Seguridad Desktop App 3CX

Posted on March 30th, 2023 by David Rojas, Marketing Manager - España, 3CX

Actualización: La lista de versiones Mac ha sido actualizada el 01/04 11AM para reflejar que uno de ellos se envió con el Update 6.

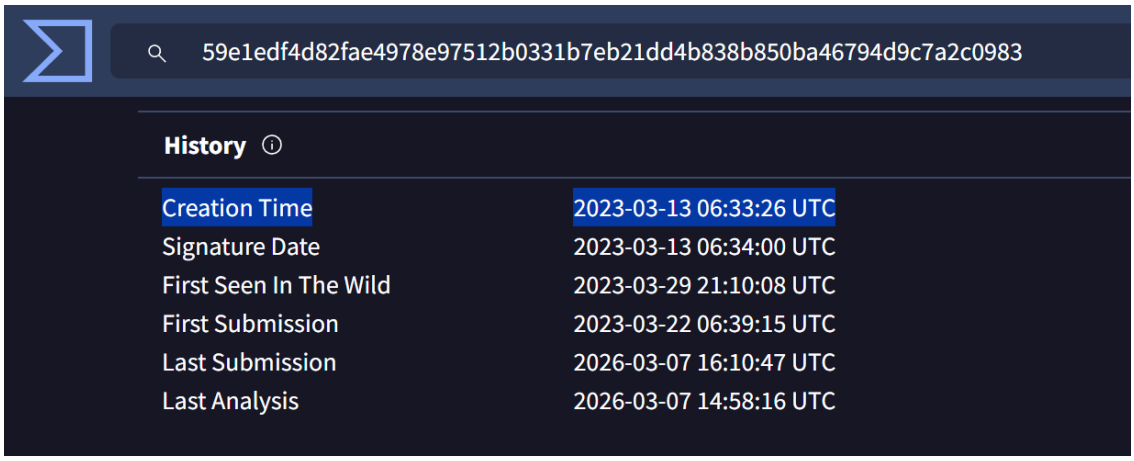
Lamentamos informar a nuestros Partners y clientes que nuestra App Windows Electron lanzada en el Update 7, con los números de versión **18.12.407 y 18.12.416**, incluye un problema de seguridad. Los proveedores de antivirus han marcado el ejecutable 3CXDesktopApp.exe y, en muchos casos, lo han desinstalado. La App Electron Mac, con los números de versión **18.11.1213 (lanzada con el Update 6), 18.12.402, 18.12.407 & 18.12.416 (Update 7)** también se han visto afectadas.

El problema parece ser una de las bibliotecas incluidas que compilamos en la App Windows Electron a través de GIT. Todavía estamos investigando el asunto para poder brindar una respuesta más detallada hoy. Aquí puede encontrar información sobre lo que hemos hecho hasta ahora.

P2: Determinar la antigüedad del malware puede ayudar a evaluar el alcance de la vulneración y a rastrear la evolución de las familias y variantes de malware. ¿Cuál es la hora UTC de creación del malware .msi?

R: 2023-03-13 06:33

Se analizaron los detalles del malware .msi con VirusTotal y se halló la fecha de creación 2023-03-13 06:33.



59e1edf4d82fae4978e97512b0331b7eb21dd4b838b850ba46794d9c7a2c0983

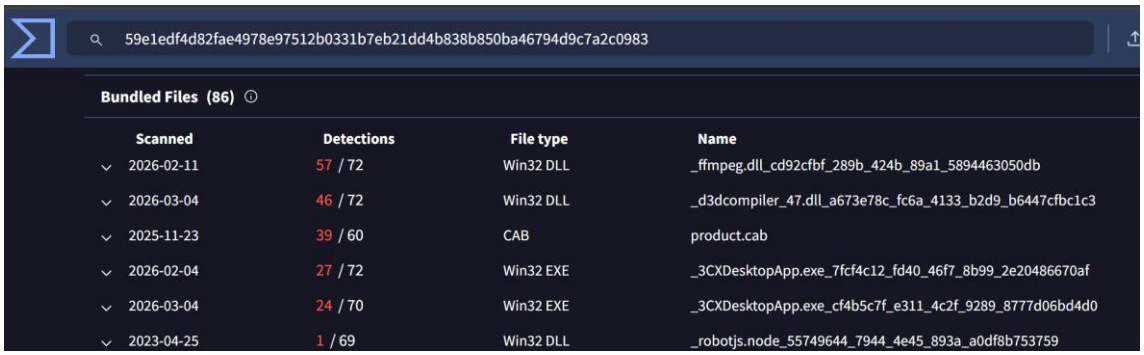
History

Creation Time	2023-03-13 06:33:26 UTC
Signature Date	2023-03-13 06:34:00 UTC
First Seen In The Wild	2023-03-29 21:10:08 UTC
First Submission	2023-03-22 06:39:15 UTC
Last Submission	2026-03-07 16:10:47 UTC
Last Analysis	2026-03-07 14:58:16 UTC

P3: Los archivos ejecutables (.exe) se utilizan frecuentemente como cargas útiles de malware, ya sea principal o secundario, mientras que las bibliotecas de vínculos dinámicos (.dll) suelen cargar código malicioso o mejorar su funcionalidad. Analizar los archivos empaquetados por el Instalador de Software de Microsoft (.msi) es crucial para identificar archivos maliciosos e investigar todo su potencial. ¿Qué DLL maliciosas se empaquetaron en el archivo .msi?

R: ffmpeg.dll,d3dcompiler_47.dll

Se investigaron las relaciones que tiene el malware y se encontró que entre los archivos incluidos maliciosos existen 2 archivos DLL: ffmpeg.dll y d3dcompiler_47.dll.



P4: Reconocer las técnicas de persistencia empleadas en este incidente es esencial para las estrategias de mitigación actuales y las futuras mejoras de defensa. ¿Cuál es el ID de la técnica MITRE empleado por los archivos .msi para cargar la DLL maliciosa?

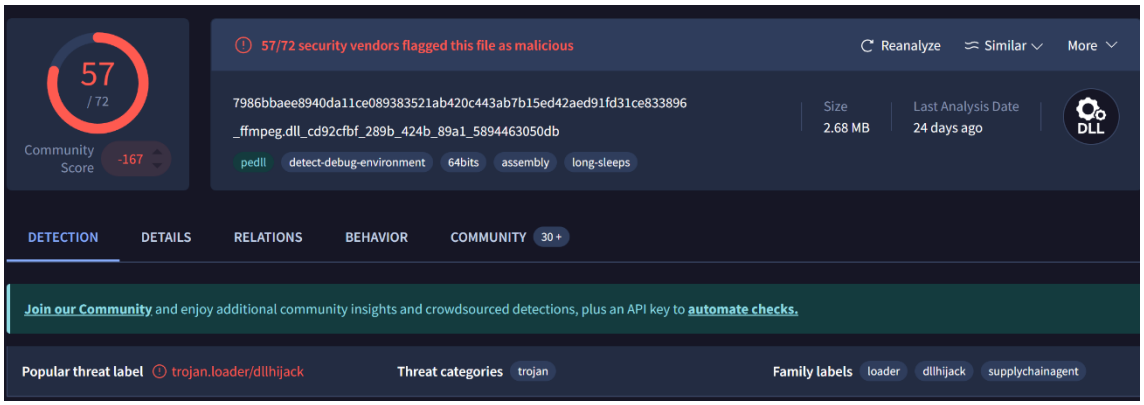
R: T1574

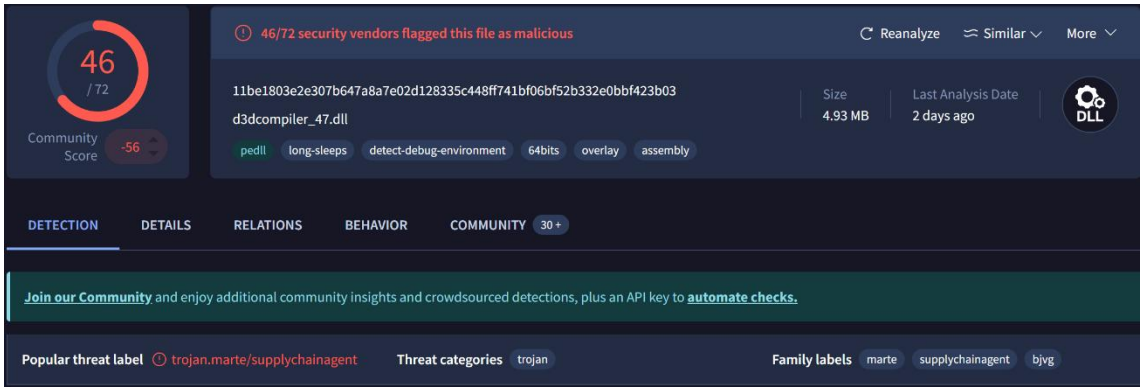
La técnica empleada está mapeada en MITRE con el ID T1574 Hijack Execution Flow.

P5: Reconocer el tipo de malware (categoría de amenaza) es esencial para su investigación, ya que puede ofrecer información valiosa sobre las posibles acciones maliciosas que examinará. ¿Cuál es la categoría de amenaza de las dos DLL maliciosas?

R: trojan

Ambos están categorizados como troyanos por VirusTotal.

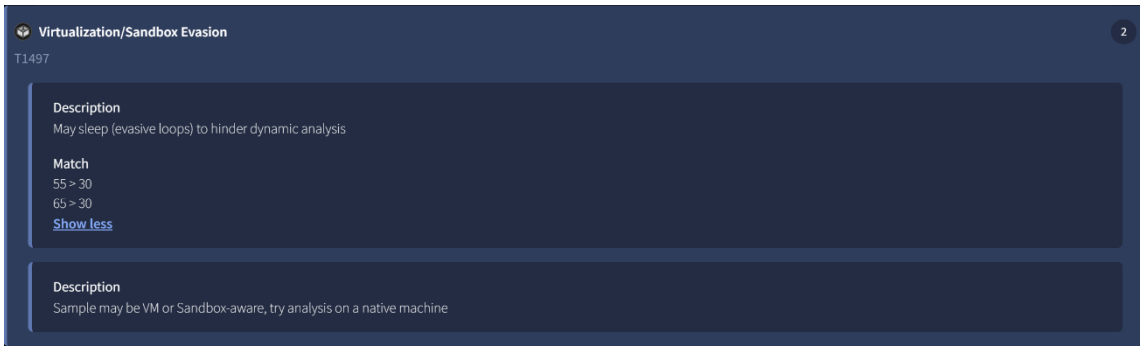




P6: Como analista de inteligencia de amenazas que realiza análisis dinámicos, es fundamental comprender cómo el malware puede evadir la detección en entornos virtualizados o sistemas de análisis. Este conocimiento le ayudará a mitigar o abordar eficazmente estas tácticas evasivas. ¿Cuál es el ID de MITRE para las técnicas de evasión de virtualización/sandbox utilizadas por las dos DLL maliciosas?

R: T1497

La técnica empleada esta mapeada en MITRE con el ID T1497 Virtualization/Sandbox Evasion.



P7: Al realizar análisis de malware e ingeniería inversa, comprender las técnicas de antianálisis es vital para evitar pérdidas de tiempo. ¿Qué hipervisor es el objetivo de las técnicas de antianálisis del archivo ffmpeg.dll?

R: VMWare

Se analizó el archivo ffmpeg.dll con VirusTotal y se determinó que, en los detalles de la técnica mapeada Virtualization/Sandbox Evasion, el archivo DLL detecta la presencia del hipervisor de tipo 2 (VMWare) para el análisis dinámico.

P8: Identificar el método criptográfico empleado en el malware es crucial para comprender las técnicas empleadas para eludir los mecanismos de defensa y ejecutar sus funciones por completo. ¿Qué algoritmo de cifrado utiliza el archivo ffmpeg.dll?

R: RC4

Una de las técnicas mapeadas que el malware usó fue Obfuscated Files or Information para evadir defensas. En los detalles se determinó que el algoritmo que usó ffmpeg.dll fue RC4.

P9: Como analista, ha reconocido algunas TTP implicadas en el incidente, pero identificar al grupo APT responsable le ayudará a buscar sus TTP habituales y a descubrir otras posibles actividades maliciosas. ¿Qué grupo es responsable de este ataque?

R: Lazarus

Se investigó el ataque denominado “SmoothOperator” donde los atacantes lograron troyanizar un binario legítimo y firmado de la aplicación 3CXDesktopApp para sus actividades maliciosas. Este ataque se atribuyó al grupo norcoreano de APT Labyrinth Chollima, un subgrupo del grupo Lazarus.

3CX Desktop App Supply Chain Attack (SmoothOperator) Analysis

HUSEYIN CAN YUCEEL | 5 MIN READ
LAST UPDATED ON APRIL 27, 2023

SUMMARIZE WITH: ChatGPT perplexity Google AI

On March 29, 2023, CrowdStrike disclosed that 3CXDesktopApp, a popular softphone application from 3CX, was compromised as a part of a supply chain attack [1]. Adversaries were able to trojanize a legitimate and signed binary 3CXDesktopApp for their malicious activities. The attack, dubbed "SmoothOperator", was attributed to a North Korean APT group Labyrinth Chollima, a subset of the notorious Lazarus group.

Picus Labs added new attack simulations for 3CX Desktop App supply chain compromise and related second-stage payloads to Picus Threat Library. In this blog, we explained the malicious techniques used by Labyrinth Chollima and how to mitigate them.